

Edge protection: CloudFront, OAC and AWS WAF

Domain 3 opens here. Saying no as far from your application as possible.

Edge protection is worthless if the origin is still reachable **directly**.

CloudFront as a security control

- ◆ It **terminates TLS at the edge** and can require HTTPS from viewers, redirecting or rejecting plain HTTP.
- ◆ It is the **attachment point for a WAF web ACL** and for Shield Advanced protections.
- ◆ It absorbs volumetric traffic across the AWS edge network, so layer 3 and 4 attacks never reach your origin.
- ◆ **Geo restriction** allows or blocks by country at the distribution, before WAF even sees the request.
- ◆ A web ACL for CloudFront has **scope CLOUDFRONT** and must be created in **us-east-1**, wherever you work.

ON THE EXAM

Geo restriction on the distribution and a WAF geo match rule both block by country. The distribution is cheaper; WAF is more expressive.

Origin access control, or origin access identity?

OAC - CURRENT

Use this

- Signs requests with SigV4
- Supports SSE-KMS encrypted objects
- All Regions, including opt-in ones
- Also S3, Lambda URLs, MediaPackage

OAI - LEGACY

Migrate off it

- A special CloudFront principal in the policy
- Cannot read SSE-KMS encrypted objects
- S3 origins only
- Still works; no longer recommended

THE TIEBREAKER

The deciding fact: OAI cannot read SSE-KMS objects. Encrypt a bucket with a customer managed key and OAI breaks.

Controlling who gets the content

- ◆ **Signed URLs** for one file. **Signed cookies** when a viewer needs many files without rewriting each URL.
- ◆ Both carry an expiry, and optionally an IP range and start time.
- ◆ **Geo restriction** uses a country allow or block list at the distribution. WAF geo match is the expressive version.
- ◆ **S3 CORS**, named in skill 3.1.2, is a **browser** control – not an authorisation control.
- ◆ CORS never protects data. A public bucket is public regardless of its CORS policy.

ON THE EXAM

CORS: may this page call this bucket. Bucket policy: may this principal read this object.

Stopping people going round the edge

- ◆ For an **ALB or custom origin**, OAC does not apply. The load balancer has a public DNS name anybody can resolve.
- ◆ **Add a custom header** at CloudFront with a secret value; a WAF rule on the ALB blocks requests lacking it.
- ◆ Restrict the ALB security group to the **CloudFront managed prefix list**.
- ◆ The prefix list stops non-CloudFront IPs. The header stops **somebody else's** distribution.
- ◆ Rotate the header value – it is a shared secret in a distribution config.

ON THE EXAM

The prefix list alone is not enough. Any CloudFront distribution comes from those same ranges.

Anatomy of a web ACL

- ◆ A **web ACL** holds rules and rule groups with a **priority**. First terminating action wins.
- ◆ The **default action** applies only to requests no rule matched.
- ◆ Attach to **CloudFront, ALB, API Gateway, AppSync, Cognito user pools, App Runner or Verified Access**.
- ◆ **Scope-down statements** narrow where an expensive rule applies – bot control on /login only.
- ◆ **Labels** let one rule mark a request and a later rule act on the mark.

ON THE EXAM

Most 'why did WAF allow this' questions are ordering questions.

The five rule actions

ACTION	WHAT HAPPENS	TERMINATING?
Allow	Request goes to the origin	Yes
Block	403 by default; you can customise the response	Yes
Count	Recorded and evaluation continues to the next rule	No
CAPTCHA	Puzzle for a human; a valid token lets it through	Yes, until solved
Challenge	Silent browser challenge, no user interaction	Yes, until solved

ON THE EXAM

Count is how you deploy a rule safely. CAPTCHA asks a human; Challenge asks the browser. Bots fail both, users notice only one.

Managed rule groups

- ◆ **Core rule set** and **known bad inputs** cover the OWASP Top 10 shapes. Named in skill 3.1.2.
- ◆ **IP reputation**, **Anonymous IP**, plus database and OS specific groups.
- ◆ **Bot Control: Common** catches self-identifying bots; **Targeted** adds fingerprinting and ML for bots that hide.
- ◆ **Fraud Control** – account takeover, and account creation fraud prevention.
- ◆ **Anti-DDoS**, June 2025, replaces Shield Advanced automatic mitigation from 1 January 2027.

ON THE EXAM

Marketplace rule groups are also supported – skill 3.1.4's 'third-party WAF rules'.

Rate-based rules, and why IP is not enough

- ◆ Counts requests per **aggregation key** over a window, and acts above your limit.
- ◆ **IP is the default, and botnets defeat it** by rotating thousands of residential addresses.
- ◆ Aggregate on **JA3 or JA4 fingerprint**, header, cookie, query argument, URI path, method, label, or combinations.
- ◆ JA4 added **March 2025**, derived from the TLS Client Hello – the client's software, not its address.
- ◆ Windows of **1, 2, 5 or 10 minutes**. Set a **fallback behaviour** if the fingerprint cannot be computed.

ON THE EXAM

Rotating IPs is cheap. Rotating every bot's TLS stack is not. That asymmetry is the point.

Deploying rules without breaking the site

- ◆ **Deploy in Count first.** Watch the logs and the sampled requests, then switch to Block once you know what it catches.
- ◆ If one rule in a managed group is a problem, **override that rule to Count**. Do not remove the whole group.
- ◆ Use **scope-down statements** so a noisy or costly rule only applies where it is needed.
- ◆ Check **WCU** – each rule consumes capacity, and a web ACL has a limit. Complex rule sets hit it.
- ◆ Web ACLs now support **data protection**, so sensitive fields can be redacted from WAF logs at source.

ON THE EXAM

Count-then-block is the single most useful WAF practice, and the most common right answer to 'legitimate traffic is being blocked'.

A media company serves video assets from an S3 bucket through CloudFront using an origin access identity. To meet a new compliance requirement, the security team enables SSE-KMS on the bucket with a customer managed key.

Immediately afterwards, CloudFront begins returning errors for all objects. The bucket policy still grants the origin access identity s3:GetObject, and the KMS key policy has been updated to allow the CloudFront service principal to decrypt.

What is the cause, and what should the team do?

- ☐ A OAI cannot read SSE-KMS encrypted objects; migrate the distribution to origin access control
- ☐ B The KMS key must be in us-east-1 for a CloudFront distribution; recreate it there
- ☐ C The bucket policy needs kms:Decrypt added alongside s3:GetObject
- ☐ D CloudFront caches the old objects; invalidate the distribution and the errors will clear

◆ PAUSE AND DECIDE

What is the cause, and what should the team do?

A OAI cannot read SSE-KMS objects; migrate to OAC
Correct. This is the defining functional difference between the two mechanisms, and it is exactly why AWS recommends OAC for new and existing distributions.

C Add kms:Decrypt to the bucket policy
KMS permissions live in the key policy and in IAM, not in a bucket policy. The scenario also says the key policy was already updated.

B The KMS key must be in us-east-1
Confuses two things. The web ACL for CloudFront must be in us-east-1; the KMS key must be in the bucket's Region, which it is.

D Invalidate the cache
Invalidation clears cached objects. The origin fetch itself is failing, so every fresh fetch fails identically.

THE SIGNAL

The failure appeared the instant SSE-KMS was enabled. That timing is the question telling you which change caused it.

A retailer serves its site through CloudFront with a comprehensive web ACL: managed rule groups, rate limiting and bot control. The origin is an internet-facing Application Load Balancer.

During an incident review, the team discovers that attackers found the ALB's DNS name and have been sending requests straight to it for weeks, bypassing CloudFront entirely. The ALB's security group currently allows 0.0.0.0/0 on port 443.

What should the retailer implement?

- ☐ A Attach the same web ACL to the ALB as well as the CloudFront distribution
- ☐ B Move the ALB into private subnets and add a NAT gateway for outbound traffic
- ☐ C Restrict the ALB security group to the CloudFront managed prefix list, and require a secret custom header via a WAF rule on the ALB
- ☐ D Enable CloudFront origin access control for the ALB origin

◆ PAUSE AND DECIDE

What should the retailer implement?

A Attach the same web ACL to the ALB too
A genuine improvement and it does not close the bypass – it just inspects it. A CloudFront-scoped web ACL also cannot be attached to an ALB; you would need a second, regional one.

C CloudFront prefix list on the security group, plus a secret header enforced by WAF
Correct. The prefix list excludes everything that is not CloudFront; the header excludes every CloudFront distribution that is not yours.

B Move the ALB into private subnets
CloudFront reaches origins over the public internet, so a private ALB is unreachable by the distribution. This breaks the site rather than securing it.

D Origin access control for the ALB
OAC signs requests to supported origin types – S3, Lambda function URLs, MediaPackage. It is not available for an ALB origin.

THE SIGNAL

Two controls because there are two attackers: anyone on the internet, and anyone with their own CloudFront distribution.

A bank's login endpoint is under a credential stuffing attack. Traffic comes from around 40,000 residential IP addresses, each sending only three or four requests an hour, so an existing rate-based rule limiting 100 requests per five minutes per IP never triggers.

The requests share an identical TLS client hello. Legitimate customers must not be blocked, and the security team will accept a small amount of user friction on the login path only.

What should the bank configure?

- ☐ A Lower the rate-based rule threshold to 3 requests per five minutes per IP address
- ☐ B A rate-based rule aggregating on JA4 fingerprint, scoped to /login, with a CAPTCHA action
- ☐ C Add the AWS Managed Rules Anonymous IP list rule group in Block mode
- ☐ D Enable CloudFront geo restriction for every country outside the bank's home market

◆ PAUSE AND DECIDE

What should the bank configure?

- A

 Lower the per-IP threshold to 3 per five minutes
Would catch the attack and a large share of real customers – a shared office or mobile carrier NAT easily exceeds three requests. Unacceptable false positives.
- B

 Rate-based rule on JA4, scoped to /login, CAPTCHA action
Correct. The identical TLS client hello is the shared signal across 40,000 addresses. Scoping limits friction to login; CAPTCHA lets real users through.
- C

 Anonymous IP list in Block mode
Targets VPNs, proxies and Tor. These are residential addresses, which is precisely why the botnet uses them – the list will not match.
- D

 Geo restriction outside the home market
Blunt, and the scenario never says the traffic is foreign. Residential botnets are commonly domestic, and this blocks travelling customers.

THE SIGNAL

'Identical TLS client hello' is a JA3/JA4 fingerprint described without naming it. That sentence is the answer.

A logistics company adds the Core rule set managed rule group to its production web ACL in Block mode on a Friday afternoon. Within an hour, the customer support portal stops working: a document upload feature returns 403 for every file.

Investigation shows one rule in the group, matching on request body size, is blocking the uploads. The rest of the group is catching genuine injection attempts.

What should the company do?

- ☐ A Remove the Core rule set from the web ACL and write equivalent custom rules
- ☐ B Set the web ACL default action to Allow so unmatched uploads pass
- ☐ C Raise the priority number of the Core rule set so it evaluates after the upload rule
- ☐ D Override the single offending rule to Count, and adopt Count-first deployment for future rule changes

◆ PAUSE AND DECIDE

What should the company do?

- A

 Remove the group and write custom rules
Throws away the protections that are working to fix one rule, and replaces an AWS-maintained group with rules the company must now maintain against new threats.
- B

 Set the default action to Allow
The default action applies only to requests no rule matched. These requests are matching a rule and being blocked, so this changes nothing.
- C

 Reorder so the group evaluates later
Ordering matters when an earlier rule would terminate first. Nothing here allows the uploads before the group runs, so it still reaches the blocking rule.
- D

 Override the one rule to Count, and deploy in Count first from now on
Correct. Rule-level override keeps every other protection intact, and Count-first deployment is what would have surfaced this before Friday afternoon.

THE SIGNAL

Two answers wanted: fix today's breakage, and fix the process that caused it. Only one option does both.

Five things to carry forward

- ◆ **Edge protection is worthless if the origin is reachable directly.** Always ask what stops that.
- ◆ **OAI cannot read SSE-KMS objects.** That single fact decides most OAC-versus-OAI questions.
- ◆ **Prefix list plus secret header** for an ALB origin. One excludes the internet, the other excludes other people's distributions.
- ◆ **Rate-limit on JA3 or JA4 when IPs rotate.** A shared TLS client hello is a fingerprint described in words.
- ◆ **Count first, then Block.** Override one rule, never remove the group.

ON THE EXAM

Next: Shield, Firewall Manager and IoT Core – protection applied across an organisation rather than one distribution.